

แผนเตรียมความพร้อมต่อภาวะฉุกเฉิน และแผนความต่อเนื่องทางภารกิจ (Business Continuity Plan: BCP)

สำนักเทคโนโลยีสารสนเทศ มหาวิทยาลัยอัสสัมชัญ

1. วัตถุประสงค์

- เพื่อให้สำนักเทคโนโลยีสารสนเทศมีแนวทางปฏิบัติที่ชัดเจนในการรับมือกับเหตุการณ์ฉุกเฉินที่อาจกระทบต่อระบบเครือข่าย ระบบเซิร์ฟเวอร์ ฐานข้อมูล
- เพื่อลดผลกระทบและระยะเวลาหยุดชะงักของระบบสารสนเทศให้น้อยที่สุด
- เพื่อให้สามารถกู้คืนระบบให้กลับสู่สภาพปกติได้อย่างรวดเร็วและมีประสิทธิภาพ
- เพื่อสร้างความเชื่อมั่นให้แก่ผู้บริหาร บุคลากร และนักศึกษาในความมั่นคงของระบบสารสนเทศของมหาวิทยาลัย

2. ขอบเขตของแผน

แผนนี้ครอบคลุมระบบและโครงสร้างพื้นฐานด้านเทคโนโลยีสารสนเทศของมหาวิทยาลัย ได้แก่

- ระบบเครือข่ายภายในและการเชื่อมต่ออินเทอร์เน็ต
- เซิร์ฟเวอร์ระบบปฏิบัติการ Linux (VestaCP) และ Windows (IIS)
- ระบบที่ให้บริการบนคลาวด์ (Cloud-based Services) และ Cloudflare
- ฐานข้อมูลหลัก เช่น MySQL, PostgreSQL และ Tiberio
- ระบบงานภายในและแอปพลิเคชันที่พัฒนาโดยสำนักฯ เช่น ระบบทะเบียน ระบบ LINE OA ระบบเช็คชื่อ/เข้าร่วมกิจกรรม
- ระบบสำรองข้อมูล (Backup System)

3. การประเมินความเสี่ยงและผลกระทบทางภารกิจ (Business Impact Analysis)

สำนักเทคโนโลยีสารสนเทศได้ประเมินเหตุการณ์ฉุกเฉินที่อาจเกิดขึ้น พร้อมกำหนดระยะเวลาเป้าหมายในการกู้คืนระบบ (Recovery Time Objective: RTO) และระดับข้อมูลที่ยอมรับการสูญเสียได้ (Recovery Point Objective: RPO) ดังนี้

เหตุการณ์ฉุกเฉิน	ผลกระทบต่อภารกิจ	RTO (เวลาที่ยอมรับได้)	RPO (ข้อมูลที่ยอมรับการสูญเสียได้)
เซิร์ฟเวอร์/บริการหลักล่ม	ระบบงานหยุดชะงัก นักศึกษา/บุคลากรใช้งานไม่ได้	ไม่เกิน 4 ชั่วโมง	ไม่เกิน 24 ชั่วโมง
ฐานข้อมูลกลางเสียหาย/ข้อมูลสูญหาย	กระทบข้อมูลนักศึกษา ทะเบียน และระบบที่เชื่อมโยง	ไม่เกิน 4 ชั่วโมง	ไม่เกิน 24 ชั่วโมง (ตามรอบสำรองข้อมูล)

อินเทอร์เน็ต/เครือข่ายขัดข้อง	ไม่สามารถเข้าถึงระบบจากภายนอกได้	ไม่เกิน 1 ชั่วโมง	ไม่มีข้อมูลสูญหาย
ถูกโจมตีทางไซเบอร์ (Cyber Attack)	ข้อมูลรั่วไหล ระบบถูกแทรกแซง ความน่าเชื่อถือองค์กรลดลง	ไม่เกิน 4 ชั่วโมง (ควบคุมสถานการณ์)	ขึ้นกับจุดสำรองข้อมูลล่าสุดก่อนถูกโจมตี

4. โครงสร้างทีมงานและบทบาทหน้าที่

เพื่อให้การตอบสนองต่อเหตุการณ์เป็นไปอย่างรวดเร็วและมีเอกภาพ กำหนดให้มีทีมงานรับผิดชอบดังนี้

บทบาท	หน้าที่ความรับผิดชอบ	ผู้รับผิดชอบ/ตำแหน่ง
หัวหน้าทีมตอบสนองเหตุการณ์ (Incident Commander)	ตัดสินใจสั่งการ ประสานงานภาพรวม แจ้งผู้บริหาร	ผู้อำนวยการ/หัวหน้าสำนักเทคโนโลยีสารสนเทศ
ทีมเทคนิคระบบเครือข่ายและเซิร์ฟเวอร์	ตรวจสอบ วิเคราะห์ และกู้คืนระบบเครือข่าย/เซิร์ฟเวอร์ (Linux/Windows/Cloud)	ผู้ดูแลระบบเครือข่ายและเซิร์ฟเวอร์
ทีมฐานข้อมูล	กู้คืนฐานข้อมูลจากไฟล์สำรอง ตรวจสอบความถูกต้องของข้อมูล	ผู้ดูแลฐานข้อมูล (DBA)
ทีมพัฒนาระบบ/แอปพลิเคชัน	ตรวจสอบและกู้คืนแอปพลิเคชันภายใน ระบบ LINE OA และบริการที่เกี่ยวข้อง	นักพัฒนาระบบ
ทีมสื่อสารและประสานงาน	แจ้งเตือนผู้ใช้งาน อัปเดตสถานะผ่านช่องทางสื่อสารของมหาวิทยาลัย	เจ้าหน้าที่ประชาสัมพันธ์/สำนักฯ

5. กลยุทธ์และมาตรการเตรียมความพร้อม

5.1 การป้องกันและเฝ้าระวัง

- ติดตั้งไฟร์วอลล์อย่างสม่ำเสมอและปรับปรุงระบบตรวจจับการบุกรุก (Intrusion Detection)
- ตรวจสอบ Log และเหตุการณ์ผิดปกติของระบบเป็นประจำ
- อัปเดตแพตช์ความปลอดภัยของระบบปฏิบัติการและซอฟต์แวร์อย่างต่อเนื่อง
- ตั้งค่า Cloudflare ในโหมด Full/Full Strict เพื่อป้องกันการโจมตีและเข้ารหัสการเชื่อมต่อ

5.2 การสำรองข้อมูล (Backup)

- สำรองข้อมูลฐานข้อมูลหลักตามรอบเวลาที่กำหนด (รายวัน/รายสัปดาห์) ไปยังพื้นที่จัดเก็บภายนอก เช่น Google Cloud Storage
- ตรวจสอบความสมบูรณ์ของไฟล์สำรองข้อมูลเป็นระยะ พร้อมทดสอบการกู้คืนข้อมูลจริง
- จัดเก็บสำเนาสำรองไว้มากกว่าหนึ่งแหล่ง (On-site และ Off-site/Cloud) เพื่อลดความเสี่ยงจากจุดล้มเหลวเดียว

6. ขั้นตอนการตอบสนองต่อเหตุฉุกเฉิน

6.1 ขั้นตอนเมื่อพบเหตุการณ์ผิดปกติ แจ้งเตือนทันทีเมื่อระบบตรวจพบความผิดปกติ หรือได้รับแจ้งจากผู้ใช้งาน

6.2 ขั้นตอนการควบคุมสถานการณ์ แยกระบบที่ได้รับผลกระทบออกจากเครือข่ายหลัก (หากเกี่ยวข้องกับการถูกโจมตี) เพื่อป้องกันความเสียหายลุกลาม

6.3 ขั้นตอนการกู้คืนระบบ กู้คืนระบบจากจุดสำรองข้อมูลล่าสุดที่ตรวจสอบแล้วว่าไม่มีความเสียหาย ทดสอบการทำงานของระบบก่อนเปิดให้ใช้งานจริง และแจ้งผู้ใช้งานเมื่อระบบกลับสู่สภาวะปกติ

6.4 ขั้นตอนหลังเหตุการณ์ (Post-Incident Review) ทบทวนมาตรการป้องกันเพื่อลดโอกาสเกิดเหตุการณ์ซ้ำ

7. การสื่อสารในภาวะฉุกเฉิน กำหนดช่องทางการแจ้งเตือนหลัก เช่น LINE OA, อีเมล และประกาศผ่านเว็บไซต์มหาวิทยาลัย และแจ้งสถานะความคืบหน้าเป็นระยะจนกว่าระบบจะกลับสู่สภาพปกติ

8. ทบทวนแผนและปรับปรุงแผนให้ทันสมัยเมื่อมีการเปลี่ยนแปลงโครงสร้างระบบหรือเทคโนโลยีที่ใช้งาน